

For authorized VAPT/recon:

1. Endpoints / URLs

```
curl -s https://example.com | grep -Eo 'https?://[^( ]+|/[A-Za-z0-9_./?~]+)' | sort -u
```

2. JavaScript files

```
curl -s https://example.com | grep -Eo '<script[^\>]+src=["'\\"']+[^\\"'\"]+>'  
| sort -u
```

Or:

```
wget -qO- https://example.com | grep -Eo 'src=["'\']*[^"'\\']*+\.\js[^"'\\']*' | sort -u
```

3. API endpoints in JavaScript

```
curl -s https://example.com/app.js | grep -Eoi  
'(/api/[\"'\\' ]*|https?://[\"'\\' ]+)' | sort -u
```

4. Potential keys/secrets in JS

```
curl -s https://example.com/app.js | grep -Ei  
'api[ -]?key|secret|token|access[ -]?token|authorization|password'
```

For common secret-looking patterns:

```
grep -Eoi  
'(api[_-]?key|secret|token|access[_-]?token|client[_-]?secret)[=:][\"'\n  
'''][^\"'\n']+' app.js
```

5. HTML comments

```
curl -s https://example.com | grep -Eo '<!--.*-->'
```

6. Publicly exposed information

```
curl -s https://example.com | grep -Ei  
'email|password|username|token|secret|api[_-]?key|internal|debug|admin  
,
```

7. Download JS and search everything

```
wget -q https://example.com/app.js -O app.js  
grep -Ein  
'api|endpoint|token|secret|key|password|admin|debug|internal|localhost  
' app.js
```

Best starting command:

```
curl -s https://example.com | grep -Eoi  
'<script[^>]+src=["'\`']["'\`']*'+'
```

Then download the discovered .js files and inspect them for **endpoints, comments, configuration, and accidentally exposed secrets.**

An **HTTP response header** is information that the **server sends back to your browser/client along with the HTTP response.**

Think of it as **metadata about the response.**

Basic flow

Client (Browser / curl / Burp)

|

| HTTP Request

↓

Server

|

| HTTP Response

↓

Client

An HTTP response looks like:

```
HTTP/1.1 200 OK
Content-Type: text/html
Server: nginx
Content-Length: 5230
Strict-Transport-Security: max-age=31536000
```

```
<html>
  ...
</html>
```

There are **3 main parts** here:

1. Status line

```
HTTP/1.1 200 OK
```

Tells you the result of the request.

Examples:

200 OK	→ Request successful
301 Moved Permanently	→ Redirect
302 Found	→ Temporary redirect
403 Forbidden	→ Access denied
404 Not Found	→ Resource doesn't exist
500 Internal Server Error	→ Server-side error

2. Response headers

Everything like:

```
Content-Type: text/html
Server: nginx
Content-Length: 5230
Strict-Transport-Security: max-age=31536000
```

is a **response header**.

Each one provides information or instructions to the client.

For example:

Content-Type: text/html

means:

"The response body I'm sending you is HTML."

And:

Server: nginx

means:

"This response identifies the server software/infrastructure as nginx."

And:

Strict-Transport-Security: max-age=31536000

is a **security header** telling the browser to use HTTPS for the specified period.

3. Response body

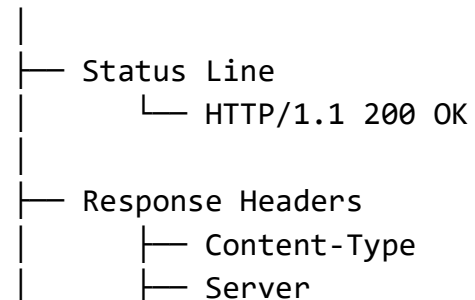
After the blank line:

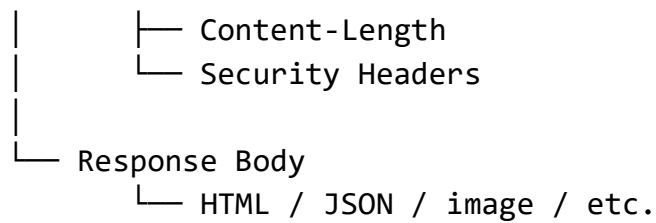
```
<html>
  <h1>Hello</h1>
</html>
```

That's the actual **content/body** being returned.

So remember this distinction

HTTP Response





Security headers are therefore a specific type of HTTP response header.

For VAPT, when you run:

```
curl -i https://example.com
```

you're essentially asking:

"Show me the HTTP response, including its headers and body."

And when you run:

```
curl -I https://example.com
```

you're asking:

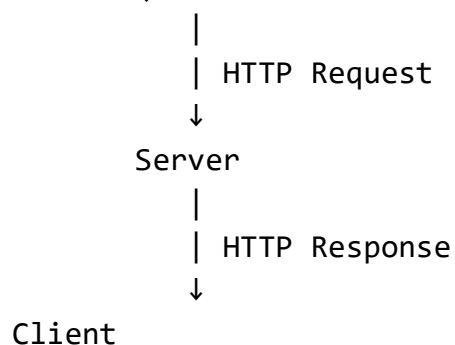
"Show me just the HTTP response headers."

An **HTTP response header** is information that the **server sends back to your browser/client along with the HTTP response.**

Think of it as **metadata about the response.**

Basic flow

Client (Browser / curl / Burp)



An HTTP response looks like:

```
HTTP/1.1 200 OK
Content-Type: text/html
Server: nginx
Content-Length: 5230
Strict-Transport-Security: max-age=31536000
```

```
<html>
  ...
</html>
```

There are **3 main parts** here:

1. Status line

```
HTTP/1.1 200 OK
```

Tells you the result of the request.

Examples:

200 OK	→ Request successful
301 Moved Permanently	→ Redirect
302 Found	→ Temporary redirect
403 Forbidden	→ Access denied
404 Not Found	→ Resource doesn't exist
500 Internal Server Error	→ Server-side error

2. Response headers

Everything like:

```
Content-Type: text/html
Server: nginx
Content-Length: 5230
Strict-Transport-Security: max-age=31536000
```

is a **response header**.

Each one provides information or instructions to the client.

For example:

Content-Type: text/html

means:

"The response body I'm sending you is HTML."

And:

Server: nginx

means:

"This response identifies the server software/infrastructure as nginx."

And:

Strict-Transport-Security: max-age=31536000

is a **security header** telling the browser to use HTTPS for the specified period.

3. Response body

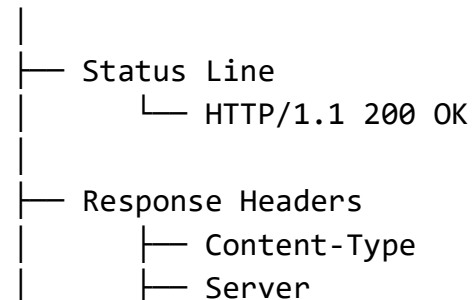
After the blank line:

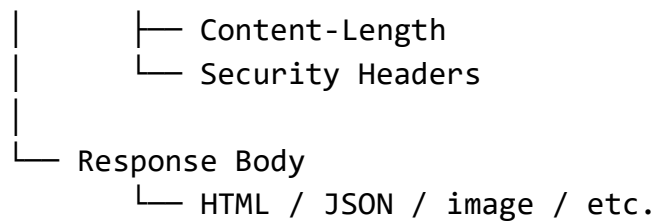
```
<html>
  <h1>Hello</h1>
</html>
```

That's the actual **content/body** being returned.

So remember this distinction

HTTP Response





Security headers are therefore a specific type of HTTP response header.

For VAPT, when you run:

```
curl -i https://example.com
```

you're essentially asking:

"Show me the HTTP response, including its headers and body."

And when you run:

```
curl -I https://example.com
```

you're asking:

"Show me just the HTTP response headers."

An **HTTP response header** is information that the **server sends back to your browser/client along with the HTTP response.**

Think of it as **metadata about the response.**

Basic flow

Client (Browser / curl / Burp)

|

| HTTP Request

↓

Server

|

| HTTP Response

↓

Client

An HTTP response looks like:


```
HTTP/1.1 200 OK
Content-Type: text/html
Server: nginx
Content-Length: 5230
Strict-Transport-Security: max-age=31536000
```

```
<html>
  ...
</html>
```

There are **3 main parts** here:

1. Status line

```
HTTP/1.1 200 OK
```

Tells you the result of the request.

Examples:

200 OK	→ Request successful
301 Moved Permanently	→ Redirect
302 Found	→ Temporary redirect
403 Forbidden	→ Access denied
404 Not Found	→ Resource doesn't exist
500 Internal Server Error	→ Server-side error

2. Response headers

Everything like:

```
Content-Type: text/html
Server: nginx
Content-Length: 5230
Strict-Transport-Security: max-age=31536000
```

is a **response header**.

Each one provides information or instructions to the client.

For example:

Content-Type: text/html

means:

"The response body I'm sending you is HTML."

And:

Server: nginx

means:

"This response identifies the server software/infrastructure as nginx."

And:

Strict-Transport-Security: max-age=31536000

is a **security header** telling the browser to use HTTPS for the specified period.

3. Response body

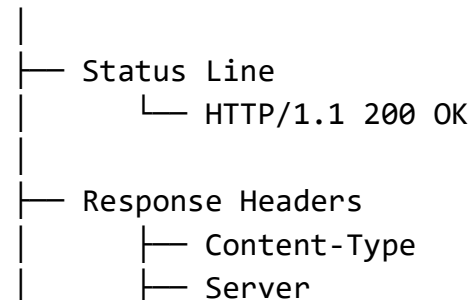
After the blank line:

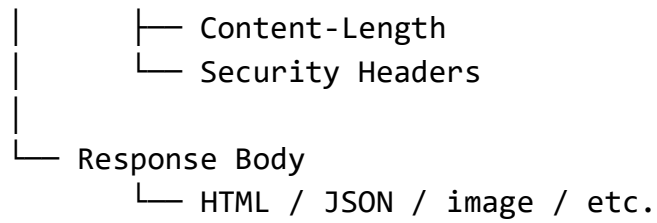
```
<html>
  <h1>Hello</h1>
</html>
```

That's the actual **content/body** being returned.

So remember this distinction

HTTP Response





Security headers are therefore a specific type of HTTP response header.

For VAPT, when you run:

```
curl -i https://example.com
```

you're essentially asking:

"Show me the HTTP response, including its headers and body."

And when you run:

```
curl -I https://example.com
```

you're asking:

"Show me just the HTTP response headers."